TLP:AMBER Restricted to the recipient's organization and its trusted clients/contractors on a need-to-know basis.

CYBER THREAT INTELLIGENCE REPORT

SonicWall SonicOS SSL-VPN flaw lets SAML logins, including SAML MFA, be bypassed and is exploited

From **Cybersecurity Briefing** · 2026-11-02 to 2026-11-07 · Briefing generated 2026-11-07

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261110-01	1.0 · 2026-11-10 07:35 EST	TLP:AMBER	United States
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-06	2026-11-09	CVE-2026-19868 (CVSS 7.1), CVE-2026-107155 (CVSS 8.8), CVE-2026-107154 (CVSS 8.8), CVE-2026-82308 (CVSS 7.5), CVE-2026-77708 (CVSS 5.9), CVE-2026-77709 (CVSS 5.9), CVE-2026-19703 (CVSS 5.1)	Nick Sturgeon

VULNERABILITY HIGH ACTIVELY EXPLOITED OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 2026-11-06 SonicWall published advisory SNWLID-2026-0014, which fixes seven flaws in SonicOS for Gen7 and Gen8 firewalls. The one that matters most is CVE-2026-19868, an authentication enforcement weakness in the SSL-VPN service. Where SSL-VPN is set up to use SAML sign-in, a person who holds a working username and password for a different login method on the same firewall can sign in to the VPN without going through SAML at all. Because most organizations enforce multi-factor authentication at the SAML identity provider, the practical effect is a password-only VPN login that skips MFA [S1] [S2] [S4] [S5].

CISA added CVE-2026-19868 to the Known Exploited Vulnerabilities catalog the same day, with a federal deadline of 2026-11-20, and the CVE record's CISA assessment marks exploitation as active [S2] [S3]. SonicWall's own wording is more cautious: it says it investigated a report of potential exploitation and has released no details. Nobody has said who was attacked, by whom, how many victims there are, or whether the flaw was used before the fix existed. As of 2026-11-09 no vendor, government agency or security firm has published indicators of compromise or a technical analysis, and no public proof of concept is reported [S5] [S6] [S7].

Exposure is narrow but real. Only firewalls running SonicOS 7.3.3-7015 or older (Gen7) or 8.2.2-8015 or older (Gen8), with SSL-VPN enabled and SAML turned on for VPN logins, are affected by the bypass. The attacker must already have a valid credential, which is why the vendor scores it 7.1 rather than critical; CISA scores it 7.5 because it treats the attacker as needing no privileges [S2] [S7]. Stolen and reused VPN passwords are common, however, and the result of a successful attack is a normal-looking VPN session with that account's network access. The EPSS score is low (0.6 percent, 50th percentile on 2026-11-09), which reflects the lack of public exploit code rather than the lack of exploitation [S9].

The fix is to upgrade to SonicOS 7.3.4-7013 (Gen7) or 8.2.3-8015 (Gen8). SonicWall lists no workaround [S1] [S4] [S5]. After patching, compare firewall SSL-VPN logins against identity provider sign-in logs and treat any VPN login that has no matching SAML and MFA event as suspect: reset that account's credentials and review what the session reached [S6]. The same firmware also closes two 8.8-rated management interface flaws, three pre-authentication buffer overflows that can crash services, and a credential-disclosure issue on virtual appliances; none of those six are reported as exploited [S5] [S7].

Key judgments

LIKELY · MODERATE CONFIDENCE
Exploitation of CVE-2026-19868 will likely grow beyond the single reported case over the next 30 days, because the precondition (a valid password for a non-SAML login method) is routinely met through credential theft and reuse, and SonicWall SSL-VPN has been a repeated target for ransomware intrusions. [S3] [S4] [S6]

VERY LIKELY · LOW CONFIDENCE
It is very likely that a working description of the bypass will become public within weeks, since the flaw is a logic error in which login method the gateway accepts rather than a memory-corruption bug, and the fixed firmware is available for comparison. [S2] [S7]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that the flaw was exploited before the patch was released. CISA listed it on the day of disclosure and the finder works at an IT services provider, which is consistent with discovery during a real incident, but neither SonicWall nor CISA has confirmed timing. [S3] [S5] [S6]

UNLIKELY · MODERATE CONFIDENCE
Organizations that patch but do not review historical SSL-VPN logins are unlikely to detect a prior compromise, because a bypassed login appears as an ordinary successful VPN session and the only reliable sign is the absence of a matching identity provider event. [S6] [S7]

UNLIKELY · MODERATE CONFIDENCE
The six other flaws fixed in the same advisory are unlikely to see broad exploitation in the near term; the two 8.8-rated management interface issues need user interaction and specific conditions, and the overflows are described only as denial-of-service. [S5] [S10]

INDICATORS OF COMPROMISE

No atomic indicators (IPs, domains, hashes) have been published by SonicWall, CISA or any security firm as of 2026-11-09. The entries below are behavioral hunting pivots: one reported by a smaller outlet and not confirmed by the vendor, the others derived from how the flaw is described. Treat them as leads, not as proof of compromise.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`SonicOS SSL-VPN login success for a SAML-enabled portal with no matching identity provider sign-in and MFA event for the same user within a few minutes`	Derived from the flaw description: the bypass produces a VPN session that never touched the SAML identity provider, so the firewall records a login that the IdP (for example Entra ID or Okta) does not. This is the review step recommended in press reporting.	DERIVED		[S2] [S6] [S7]
other	`SonicOS log event ID 1080 (SSL-VPN remote user login allowed) where the recorded authentication method is not SAML`	Reported by one smaller outlet as the log event generated by a bypassed login; it also names event ID 263 for logout. Not confirmed by SonicWall. Whether the event records the authentication method depends on firmware and log settings; another write-up warns the login may look fully normal.	REPORTED		[S8] [S7]
other	`Local, LDAP/AD or RADIUS user accounts that are members of the SSL-VPN services group on a firewall where SAML is the intended VPN login method`	Derived exposure indicator. The flaw needs a valid credential for an alternate method; any such account is a usable path. The advisory does not say which alternate methods trigger the flaw; the list of methods is an outlet's reading.	DERIVED		[S2] [S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
port	`4433/tcp`	Default SonicOS SSL-VPN listener port named in one outlet's hunting guidance. Derived as the service an exploit must reach; many deployments use 443 or a custom port instead. Use to scope exposure, not as a sign of attack.	DERIVED		[S8]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The attacker starts with a valid username and password for an account on the firewall that can authenticate by a method other than SAML (the advisory does not say which methods; local, LDAP and RADIUS are the obvious candidates). On a vulnerable SonicOS build with SAML enabled for SSL-VPN, the attacker presents that credential to the SSL-VPN service in a way that the gateway accepts without sending the user to the SAML identity provider. No SAML assertion is issued, so conditional access and MFA at the identity provider never run. The attacker receives a normal SSL-VPN session with that account's network access. The sources describe no code execution or privilege gain on the firewall itself; what happens next depends on what the VPN user can reach. The exact request sequence has not been published, and no post-compromise activity has been reported [S2] [S6] [S7].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1133 External Remote Services	Attacker connects to the internet-facing SonicOS SSL-VPN service and obtains a VPN session without completing the SAML login the organization intended to require. [S2] [S3] [S6]	Correlate firewall SSL-VPN login events with identity provider sign-in logs; alert on VPN sessions with no matching SAML sign-in. Alert on VPN logins from new countries, hosting providers or anonymizing networks.
Defense Evasion	T1078 Valid Accounts	The bypass requires working credentials for an alternate authentication method on the firewall; the session is established as that legitimate user and looks like a routine login. [S2] [S7]	Baseline which accounts normally sign in through SAML and flag any that authenticate by another method. Watch for logins by dormant, service or break-glass accounts.

Tactic	Technique	Procedure observed	Detection opportunity
Credential Access	T1556 Modify Authentication Process (closest mapping: MFA enforcement circumvented, not modified)	Analyst mapping. The attacker does not alter the authentication process; a flaw in enforcement lets a single-factor login stand in for the SAML and MFA flow (CWE-308). No exact ATT&CK technique exists for a vendor logic flaw of this kind. [S2] [S3]	After patching, test that a non-SAML credential is refused on the SSL-VPN portal. Audit firewall configuration for unexpected changes to user authentication settings.
Credential Access	T1110.004 Brute Force: Credential Stuffing	Assessed, not reported. The sources do not say how the attacker in the reported case got credentials. Password reuse and stuffing against VPN portals is the most common way to satisfy the precondition. [S6] [S8]	Alert on bursts of failed SSL-VPN logins across many usernames from one source, followed by a success. Enable login lockout and botnet/geo-IP filtering on the WAN interface.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

SonicOS SSL-VPN login that did not use SAML `SPLUNK SPL`

```
index=network sourcetype=sonicwall* (m=1080 OR msg="*SSL VPN zone remote user login allowed*")
| eval auth_method=coalesce(auth, authMethod, "unknown")
| where NOT like(lower(auth_method), "%saml%")
| stats count min(_time) as first_seen max(_time) as last_seen values(src) as src_ips by usr, auth_method, dvc
| convert ctime(first_seen) ctime(last_seen)
```

Event ID 1080 and the auth field come from a single unconfirmed outlet [S8]; field names vary by add-on and firmware. If the log carries no authentication method, this query returns every login as 'unknown' and the IdP correlation below is the only reliable check. Run over at least 30 days.

SSL-VPN login with no matching Entra ID sign-in `KQL`

```
let window = 5m;
let vpn = CommonSecurityLog
| where TimeGenerated > ago(30d)
| where DeviceVendor =~ "SonicWall"
| where DeviceEventClassID == "1080" or Activity has "SSL VPN zone remote user login allowed"
| extend User = tolower(coalesce(SourceUserName, DestinationUserName))
| project VpnTime = TimeGenerated, User, SourceIP, Computer;
let idp = SigninLogs
| where TimeGenerated > ago(30d)
| where ResultType == 0
| where AppDisplayName has_any ("SonicWall", "SSL VPN", "SSLVPN")
| extend User = tolower(UserPrincipalName)
| project IdpTime = TimeGenerated, User;
vpn
| join kind=leftouter idp on User
| extend Matched = iff(isnotempty(IdpTime) and abs(datetime_diff('second', VpnTime, IdpTime)) <= 300, 1, 0)
| summarize Matched = max(Matched) by VpnTime, User, SourceIP, Computer
| where Matched == 0
```

Adjust the AppDisplayName filter to the name of your SAML enterprise application and normalize usernames (the firewall may log a short name while Entra logs a UPN). Legitimate break-glass local accounts will appear; confirm each one.

SonicWall SSL-VPN login without SAML (generic) `SIGMA`

```
title: SonicWall SSL-VPN Login Without SAML Authentication
status: experimental
description: Successful SonicOS SSL-VPN login where the logged authentication method is not SAML, on firewalls where SAML is the required
method (CVE-2026-19868)
logsource:
  product: sonicwall
  service: firewall
detection:
  selection:
    event_id: 1080
  filter_saml:
    auth_method|contains: 'SAML'
  condition: selection and not filter_saml
falsepositives:
  - Documented break-glass or service accounts that use local authentication
  - Firmware that does not record the authentication method
level: high
```

Field names (event_id, auth_method) are placeholders; map them to your pipeline. Only meaningful on firewalls where SAML is the sole intended SSL-VPN login method.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
SonicWall SonicOS Gen7 (TZ, NSa, NSsp, NSv) with SSL-VPN using SAML	7.3.3-7015 and earlier	7.3.4-7013 and later	CVE-2026-19868	7.1 (SonicWall) / 7.5 (CISA ADP)	0.006 (0.62%, 50th percentile, 2026-11-09)	Yes (added 2026-11-06)	2026-11-20

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
SonicWall SonicOS Gen8 (TZ, NSa, NSv) with SSL-VPN using SAML	8.2.2-8015 and earlier	8.2.3-8015 and later	CVE-2026-19868	7.1 (SonicWall) / 7.5 (CISA ADP)	0.006 (0.62%, 50th percentile, 2026-11-09)	Yes (added 2026-11-06)	2026-11-20
SonicWall SonicOS Gen7 and Gen8 (management interface, SSL-VPN service, TACACS+ client, virtual appliances)	Gen7 7.3.3-7015 and earlier; Gen8 8.2.2-8015 and earlier	7.3.4-7013; 8.2.3-8015	CVE-2026-107155, CVE-2026-107154, CVE-2026-82308, CVE-2026-77708, CVE-2026-77709, CVE-2026-19703	8.8, 8.8, 7.5, 5.9, 5.9, 5.1	Not retrieved	No	N/A

Immediate (0–24 hours)

- Inventory every SonicWall Gen7 and Gen8 firewall, record its SonicOS build, and note whether SSL-VPN is enabled and whether SAML is used for VPN logins. Firewalls with both are the priority. `IT OPS` [S1] [S5] [S7]
- Upgrade affected firewalls to SonicOS 7.3.4-7013 (Gen7) or 8.2.3-8015 (Gen8), starting with internet-facing SSL-VPN gateways that use SAML. Confirm the running build after reboot. There is no vendor workaround. `IT OPS` [S1] [S4] [S5]
- Pull at least 30 days of SSL-VPN login events and compare them with identity provider sign-in logs. Flag any VPN login with no matching SAML and MFA event. `SOC` [S6] [S7]
- For every flagged login that cannot be explained, reset the account's password, end its active sessions, and review what the VPN session accessed. Escalate to incident response if internal systems were touched. `SOC` [S6]

Short term (1–7 days)

- List all accounts that can authenticate to SSL-VPN by a non-SAML method (local, LDAP, RADIUS). Remove SSL-VPN access from those that do not need it and keep only documented break-glass accounts with long unique passwords. `IT OPS` [S7] [S8]
- Rotate passwords for local firewall users and for directory or RADIUS service accounts bound to the firewall, since a valid credential is the only thing an attacker needs on an unpatched device. `IT OPS` [S8]

- Forward SonicOS SSL-VPN login and logout events to the SIEM and deploy a standing alert for VPN logins that lack a matching identity provider sign-in. `SOC` [S6] [S8]
- After patching, test that a non-SAML credential is refused at the SSL-VPN portal, and record the result as evidence of remediation. `IT OPS` [S7]
- Confirm the firewall management interface is not reachable from the internet; the same firmware fixes two 8.8-rated management interface flaws. `IT OPS` [S5] [S10]

Long term

- Plan replacement of any Gen6 or older SonicWall firewalls. They are not listed as affected but are past end of support and will not receive fixes for future flaws. `LEADERSHIP` [S6]
- Set a service level for edge-device patches: KEV-listed flaws on firewalls and VPN gateways patched within days, with an approved emergency change path. `LEADERSHIP` [S3]
- Reduce reliance on a single VPN login as the gate to the internal network: segment what VPN users can reach, require device posture checks, and evaluate identity-aware access in place of broad network VPN. `LEADERSHIP` [S6] [S7]

Workarounds & compensating controls

- If patching must wait, restrict SSL-VPN access to known source addresses or countries. This narrows who can attempt the bypass but does not fix it. `IT OPS` [S7] [S8]
- If patching must wait, remove or disable non-SAML accounts from SSL-VPN access. This is not a vendor-endorsed mitigation and may not close every path; treat it as risk reduction only. `IT OPS` [S7] [S8]
- Increase monitoring on unpatched gateways: review every SSL-VPN login daily against identity provider logs until the upgrade is done. `SOC` [S6]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] SonicWall PSIRT: SNWLID-2026-0014: SonicOS multiple vulnerabilities
Published 2026-11-06 · `A2` Completely reliable, probably true
Primary vendor advisory. The page is script-rendered and its body could not be read directly during research; its contents are taken from the CVE records it feeds and from press reporting that quotes it.

[S2] CVE Program (MITRE): CVE-2026-19868 record
Published 2026-11-06 · `A1` Completely reliable, confirmed by other sources
Description, CWE-308, affected versions, CISA ADP score 7.5 and SSVC (exploitation active, not automatable, partial impact). Last updated 2026-11-07.

[S3] CISA: Known Exploited Vulnerabilities catalog entry for CVE-2026-19868
Published 2026-11-06 · `A1` Completely reliable, confirmed by other sources
Read from the KEV JSON feed. Added 2026-11-06, due 2026-11-20, ransomware use Unknown, cites BOD 26-04.

[S4] BleepingComputer: SonicWall warns of new SSL-VPN MFA bypass flaw exploited in attacks
Published 2026-11-06 · `B2` Usually reliable, probably true
Briefing source. Versions, vendor statement, finder credit, recent SMA1000 context.

[S5] SecurityWeek: SonicWall Patches Exploited SonicOS Vulnerability That Weakens VPN Logins
Published 2026-11-07 · `B2` Usually reliable, probably true
Briefing source. Describes the six other flaws; notes zero-day status is unclear. Publication date inferred from the briefing's update date.

[S6] Help Net Security: Exploited SonicWall SSL-VPN flaw lets attackers bypass SAML-enforced MFA (CVE-2026-19868)
Published 2026-11-09 · `B2` Usually reliable, probably true
Most recent reporting. Confirms no IOCs or third-party analysis yet; gives log review advice; Gen6 end-of-support note; prior SonicWall MFA bypass history.

[S7] Ostorlab: SonicWall SSLVPN SAML Bypass, Exploited in the Wild (CVE-2026-19868)
Published 2026-11-07 · `C2` Fairly reliable, probably true
Summarizes the advisory including vendor CVSS vector and the six companion CVE IDs. States plainly that no request pattern, root cause or IOCs are public. Exploitation steps are the author's reconstruction.

[S8] Decryption Digest: SonicWall SSLVPN SAML MFA Bypass Exploited: CVE-2026-19868
Published 2026-11-08 · `C3` Fairly reliable, possibly true
Source of the event ID 1080/263 hunting guidance and sample rules. Contains unsourced claims (known ransomware use, pre-disclosure exploitation) that conflict with CISA's 'Unknown' and are not relied on here.

[S9] FIRST: EPSS score for CVE-2026-19868
Published 2026-11-09 · `A2` Completely reliable, probably true
EPSS 0.00621, percentile 0.50063, dated 2026-11-09.

[S10] CVE Program (MITRE): CVE records for companion flaws (CVE-2026-107155, CVE-2026-107154, CVE-2026-82308, CVE-2026-19703)
Published 2026-11-06 · `A1` Completely reliable, confirmed by other sources
Four of the six companion records were opened and match the advisory: cross-domain policy (CWE-942, 8.8), session validation (CWE-291, 8.8), SSL-VPN heap overflow (CWE-122, 7.5), virtual appliance credential disclosure (5.1). The two TACACS+ records (CVE-2026-77708, CVE-2026-77709) were not opened and rest on S7.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-08-14	CVE-2026-19868 reserved by SonicWall.	[S2]
2026-11-06	SonicWall publishes advisory SNWLID-2026-0014 and fixed firmware 7.3.4-7013 and 8.2.3-8015; CVE records published.	[S1] [S2] [S4]
2026-11-06	CISA adds CVE-2026-19868 to the KEV catalog with a 2026-11-20 due date.	[S3]

Date	Event	Source
2026-11-07	CVE record updated with CISA ADP scoring (7.5) and SSVC 'active' exploitation. SecurityWeek reports zero-day status is unclear.	[S2] [S5]
2026-11-09	Help Net Security reports that no indicators or third-party analysis have been published. EPSS stands at 0.62 percent.	[S6] [S9]
2026-11-20	CISA remediation deadline for federal civilian agencies.	[S3]

Relevance to Indianapolis, Indiana & managed clients

SonicWall TZ and NSa firewalls are among the most common edge devices in Indiana small and mid-size businesses, K-12 districts, municipal and county offices, clinics and smaller manufacturers, and many of those sites use the built-in SSL-VPN for remote staff and vendors. Organizations that moved VPN sign-in to SAML with Microsoft Entra ID or a similar provider did so precisely to enforce MFA and conditional access, often to satisfy cyber insurance terms; this flaw quietly removes that control while the configuration still looks correct. Healthcare providers should weigh the HIPAA implications of a password-only path into networks holding patient data, and public bodies should note the Indiana requirement to report cybersecurity incidents to the Indiana Office of Technology within two business days if a review turns up unauthorized VPN access. For managed IT service clients, the practical work is a fleet-wide check of SonicOS builds and SAML use, an emergency firmware window for affected gateways, and a one-time comparison of firewall VPN logins against identity provider logs. The flaw was reported by a researcher at an IT services provider, which suggests it surfaced in a managed-services setting much like those serving local organizations. Sites still on Gen6 hardware are not affected by this bug but are out of support and should be on a replacement plan.

Intelligence gaps

- The body of the SonicWall advisory could not be read directly (script-rendered page). Version, scoring and workaround details come from CVE records and press reports that agree with each other; verify against the advisory before change approval.
- No details of the reported exploitation: victim, sector, date, actor, or what the attacker did after logging in. It is unknown whether exploitation predates the patch.
- The exact trigger is unpublished: which alternate authentication methods work, which endpoint or client is used, and whether the login is distinguishable in default logs.
- No vendor or government indicators of compromise. Event ID 1080 and the auth-method field come from one smaller outlet and are unconfirmed.
- CISA lists ransomware use as Unknown. Watch for linkage to ransomware affiliates that have targeted SonicWall SSL-VPN before.
- Whether SonicWall cloud-managed or NSM-pushed configurations change exposure is not stated.
- The CVE records for the two TACACS+ overflows (CVE-2026-77708, CVE-2026-77709) were not opened; their IDs and 5.9 scores rest on one

secondary source.
- Watch for: a SonicWall knowledge-base article with log guidance, a CISA alert, third-party technical analysis or proof of concept, and scanning activity reports from sensor networks.

Other notes

- Scoring differs by source: SonicWall rates CVE-2026-19868 at 7.1 (privileges required: low) and CISA's ADP entry at 7.5 (privileges required: none). The rest of the vector is the same. The briefing's noted discrepancy is explained by this.
- CVE-2026-19703 is scored 5.1 in its CVE record and 5.2 in one secondary write-up; the record's CWE (hard-coded credentials) also does not match the weak-hashing description.
- One outlet states the flaw has known ransomware use and that attackers knew of it before disclosure. Neither claim is sourced and the first contradicts the KEV entry; both are excluded from the judgments above.
- The same outlet suggests rate-limiting requests to an '/auth/' path on port 4433. No primary source ties that path to the flaw, so it is not listed as an indicator.
- Only firewalls using SAML for SSL-VPN logins are exposed to the bypass, but the other six fixes apply to all Gen7 and Gen8 devices, so the upgrade is warranted regardless of SAML use.
- Context: this is the latest in a run of SonicWall remote-access problems. Press reporting cites 2025 Akira intrusions through SonicWall VPNs despite one-time-password MFA, exploitation of the earlier SSL-VPN MFA bypass CVE-2024-12802, and several SMA1000 zero-days in 2026. SMA appliances are a separate product line and are not covered by this advisory.
- Both the vulnerable and fixed Gen8 builds end in -8015 (8.2.2-8015 versus 8.2.3-8015). This is consistent across the CVE record and press reports; check the full version string, not just the build suffix.

CTI-20261110-01 v1.0 · Generated 2026-11-10 07:35 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:AMBER Restricted to the recipient’s organization and its trusted clients/contractors on a need-to-know basis.